

Clase 001 — Qué es la ciberseguridad: tríada CIA, AAA, superficie de ataque y defensa en profundidad

Parte: **0 — Fundamentos y prerequisites** · Fuente: *NIST SP 800-12 Rev. 1 / CSF 2.0* 🕒 Duración estimada: **90 min** · Nivel: **Fundamentos**

🎯 Objetivo

Construir el vocabulario y los modelos mentales sobre los que descansa todo el programa. Al terminar sabrás qué protege realmente la ciberseguridad (no "los hackers malos", sino propiedades concretas de la información), cómo se controla el acceso a los sistemas, qué es la superficie de ataque de un activo y por qué ninguna defensa aislada es suficiente.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Definir** las tres propiedades de la tríada CIA y dar un ejemplo de ataque contra cada una.
- 2. **Distinguir** las tres A del modelo AAA (autenticación, autorización, accounting) y ubicarlas en un flujo de acceso.
- 3. **Enumerar** los componentes de la superficie de ataque de un sistema y proponer cómo reducirla.
- 4. **Explicar** el principio de defensa en profundidad con capas concretas.
- 5. **Relacionar** cada concepto con controles reales (cifrado, MFA, logs, segmentación).

📖 Temas

#	Tema	Por qué importa
1	Tríada CIA	Define qué se protege; es el criterio para evaluar cualquier control
2	Propiedades extendidas	Autenticidad, no repudio y trazabilidad completan CIA
3	Modelo AAA	Rige el acceso; la mayoría de brechas son fallos de AAA
4	Superficie de ataque	Lo que no existe no se puede atacar; base del <i>hardening</i>
5	Vectores y amenazas	Distinguir amenaza, vulnerabilidad y riesgo evita confusiones
6	Defensa en profundidad	Ninguna capa es infalible; asumir compromiso
7	Principio de mínimo privilegio	Limita el daño de una cuenta comprometida
8	Modelos zero trust	Evolución moderna del perímetro

Definiciones y características

- **Confidencialidad:** garantía de que la información solo es accesible a quien está autorizado. Característica clave: se rompe con una *fuga/disclosure*; se protege con cifrado y control de acceso.
- **Integridad:** garantía de que los datos no se alteran de forma no autorizada. Se verifica con *hashes* y firmas; se rompe con manipulación (*tampering*).
- **Disponibilidad:** garantía de que el servicio está accesible cuando se necesita. Se ataca con DoS/DDoS; se protege con redundancia y capacidad.
- **Autenticación:** probar que eres quien dices ser (algo que sabes/tienes/eres). Sin ella no hay identidad fiable.
- **Autorización:** decidir qué puede hacer una identidad ya autenticada. Se implementa con RBAC/ABAC.
- **Accounting/Auditoría:** registrar quién hizo qué y cuándo. Habilita la trazabilidad y el forense.
- **Superficie de ataque:** suma de todos los puntos donde un atacante puede intentar entrar (puertos, APIs, formularios, personas). Menos superficie = menos riesgo.

Herramientas y preparación

Esta clase es conceptual, pero conviene tener papel/pizarra digital para diagramar. Instala **draw.io** (o usa <https://app.diagrams.net>) para dibujar diagramas de flujo de acceso y capas de defensa. Ten a mano el navegador para consultar el **NIST CSF 2.0** y el glosario **NIST 800-160**. No hace falta laboratorio ofensivo todavía; se prepara en la Clase 004.

Laboratorio guiado (ejercicio aplicado)

1. Elige un sistema real que conozcas (tu correo personal, un servidor web, un cajero). Anótalo.
2. **CIA por activo:** para ese sistema, escribe un ejemplo concreto de ataque que rompa (a) confidencialidad, (b) integridad, (c) disponibilidad.
3. **Flujo AAA:** dibuja en draw.io el recorrido de un login: identidad → autenticación (¿factor?) → autorización (¿qué permisos?) → accounting (¿qué se registra?).
4. **Mapa de superficie de ataque:** lista todos los puntos de entrada del sistema. Para un servidor web típico: puertos 80/443, SSH 22, panel de admin, formularios, dependencias, y el propio administrador (ingeniería social).
5. **Reducción:** junto a cada punto, escribe una medida de *hardening* (cerrar puerto, MFA, WAF, parcheo, formación).
6. **Capas de defensa:** reorganiza tus controles en capas: perímetro (firewall) → red (segmentación) → host (EDR, parches) → aplicación (validación) → datos (cifrado) → humano (concienciación).
7. Contrasta: si cae una capa, ¿qué otra frena al atacante? Esa es la esencia de la defensa en profundidad.

Ejercicios

1. Clasifica estos incidentes según qué propiedad CIA violan: ransomware, defacement de una web, robo de base de datos, ataque de amplificación DNS.
2. Explica con un ejemplo la diferencia entre **amenaza**, **vulnerabilidad** y **riesgo**.
3. Diseña un esquema AAA para una app bancaria: ¿qué factores de autenticación y qué niveles de autorización usarías?

4. Toma un dispositivo IoT doméstico y enumera su superficie de ataque completa.
5. Un servidor tiene un único control: un firewall perimetral. Argumenta por qué es insuficiente y propón tres capas más.
6. Investiga y resume en 5 líneas qué cambia el modelo **zero trust** respecto al perímetro clásico.

Reto verificable

Redacta una ficha de una página para un activo de tu elección que contenga: (1) su clasificación CIA con justificación, (2) su matriz AAA, (3) su mapa de superficie de ataque con al menos 6 puntos, y (4) un diagrama de defensa en profundidad con 4 capas mínimo.

Criterio de aceptación: la ficha vincula cada punto de la superficie de ataque a al menos un control, y cada control queda asignado a una capa de la defensa en profundidad. Un revisor debe poder señalar qué falla se contiene en qué capa.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Confundir autenticación con autorización	Autenticar = <i>¿quién eres?</i> ; autorizar = <i>¿qué puedes hacer?</i> . Recuerda el orden: primero autenticas, luego autorizas.
Tratar disponibilidad como algo "de infraestructura" y no de seguridad	Un DoS es un ataque de seguridad; la A de CIA es tan importante como las otras dos.
Creer que cifrar lo resuelve todo	El cifrado protege confidencialidad, no integridad ni disponibilidad; hacen falta firmas y redundancia.
Confundir riesgo con vulnerabilidad	Riesgo = probabilidad × impacto sobre un activo; la vulnerabilidad es solo un ingrediente.
Diseñar una sola línea de defensa "perfecta"	Asume que fallará; por eso se apilan capas.

Preguntas frecuentes

¿La tríada CIA está desactualizada? No, sigue siendo el marco base. Se ha extendido con autenticidad, no repudio y trazabilidad (modelos como *Parkerian Hexad*), pero CIA sigue siendo el punto de partida obligatorio.

¿AAA es lo mismo que MFA? No. AAA es el modelo completo (autenticación, autorización, accounting). MFA es solo una forma de reforzar la *primera* A usando varios factores.

¿Reducir la superficie de ataque no limita la funcionalidad? A veces sí, y ahí está el equilibrio: se desactiva lo que no se usa. Un servicio apagado no tiene vulnerabilidades explotables.

¿Zero trust reemplaza la defensa en profundidad? No, la complementa: zero trust elimina la confianza implícita por ubicación de red, pero sigue apilando controles en capas.

Referencias

- NIST SP 800-12 Rev. 1, *An Introduction to Information Security* — <https://csrc.nist.gov/pubs/sp/800/12/r1/final>
- NIST Cybersecurity Framework 2.0 — <https://www.nist.gov/cyberframework>
- NIST SP 800-207, *Zero Trust Architecture* — <https://csrc.nist.gov/pubs/sp/800/207/final>
- OWASP, *Attack Surface Analysis Cheat Sheet* — <https://cheatsheetseries.owasp.org/>

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Siguiendo clase

Clase 002 - El panorama de amenazas moderno: actores, motivaciones y Cyber Kill Chain